

Domain 5 Study Module

Security, Compliance, and Governance for AI Solutions

AWS Certified AI Practitioner (AIF-C01) Exam Prep Program - Task 6 of 15 Domain Weight: 14% of scored content (~7 scored questions) Based on AIF-C01 Exam Guide Version 1.1 (April 30, 2026)

PART 1: DOMAIN INTRODUCTION

Why Security and Governance Are Not Afterthoughts

It is tempting to think of security and governance as the “paperwork” stage of an AI project - something you bolt on after the model works. Domain 5 exists because that mindset is exactly backwards, and AWS wants every AI Practitioner to understand why.

Think of building an AI system like building a house. You would not frame the walls, finish the kitchen, move in furniture, and only then think about whether the doors lock or whether the wiring is up to code. Security and governance are part of the foundation - decided before the first wall goes up, and checked at every stage afterward. With AI systems, this matters even more, because AI workloads:

- Often process sensitive data (customer records, health information, financial details) at large scale.
- Produce *outputs*, not just store data - and those outputs can leak sensitive information or be manipulated by bad actors in ways traditional software cannot.
- Are increasingly subject to new regulations written specifically because lawmakers recognize AI creates novel risks.
- Are harder to audit than traditional software because their behavior is probabilistic, not purely rule-based.

A business that treats security and governance as “something the engineers handle later” is a business that discovers its mistakes the hard way - through a data breach, a failed audit, or a regulatory fine.

How Domain 5 Differs From the AWS Security Specialty

If you have heard of the AWS Certified Security - Specialty certification, it is important to understand that Domain 5 is **not** a condensed version of it. The Security Specialty certification is for security engineers who configure, deploy, and troubleshoot security controls. Domain 5 of AIF-C01 is for AI practitioners who need to:

- Recognize which AWS service or feature addresses a given AI security or governance need.
- Understand AI-specific risks (like prompt injection) that do not exist in traditional IT security.
- Have informed conversations with security and compliance teams about AI projects.
- Know what questions to ask - not necessarily how to implement the answer.

You will not be asked to configure a security group, write an IAM policy document, or design a VPC architecture on this exam. You will be asked to identify the right tool or concept for a described scenario.

The Intersection of Domain 4 (Responsible AI) and Domain 5 (Security and Governance)

Domains 4 and 5 are closely related but answer different questions:

Domain 4: Responsible AI	Domain 5: Security, Compliance, Governance
Asks: “Is this AI system fair, safe, and trustworthy?”	Asks: “Is this AI system protected, compliant, and auditable?”
Focuses on bias, fairness, explainability	Focuses on access control, encryption, regulatory compliance
Tools: SageMaker Clarify, Model Cards, A2I	Tools: IAM, KMS, Macie, CloudTrail, Audit Manager
Concerned with the <i>quality</i> of AI decisions	Concerned with the <i>protection and oversight</i> of AI systems

The two domains overlap at the edges. Amazon Bedrock Guardrails, for example, shows up in both domains - in Domain 4 it helps enforce responsible AI behavior (blocking toxic or biased outputs), and in Domain 5 it acts as a security control (blocking prompt injection attempts and filtering sensitive content). Expect exam questions that test whether you can tell these purposes apart in context.

Five Common Learner Misconceptions About AI Security

1. **“AWS handles all my security.”** False. AWS secures the cloud infrastructure (the data centers, hardware, and the underlying service). The customer is always responsible for their data, their access configuration, and how they use the service. This is the Shared Responsibility Model, covered in depth in Part 3A.
2. **“Compliance and governance are the same thing.”** False. Compliance means meeting a specific external rule, law, or standard (such as HIPAA or GDPR). Governance is the broader internal system of policies, processes, and oversight an organization uses to manage AI responsibly - compliance is one *outcome* of good governance, not a synonym for it.
3. **“Encryption solves all privacy problems.”** False. Encryption protects data from being read by unauthorized parties while it is stored or moving across a network. It does nothing to stop an authorized user from misusing data, nothing to prevent a model from memorizing and later leaking patterns from its training data, and nothing to stop a model from being tricked by prompt injection into revealing information it was never supposed to disclose.
4. **“If a model’s outputs look reasonable, there’s nothing to audit.”** False. Plausible-sounding outputs can still be hallucinated, biased, or based on stale data. Auditability is about being able to trace *how* an output was produced (what model, what inputs, what guardrails were applied) - not about whether the output happens to look correct.
5. **“Security for AI is the same as security for any other application.”** False. Traditional application security focuses on protecting code and data from unauthorized access. AI systems add new attack surfaces - prompt injection, model inversion, training data extraction, and adversarial inputs - that do not exist in conventional software and require AI-specific defenses like Amazon Bedrock Guardrails.

What a Business-Role Practitioner Needs to Understand vs. What Engineers Handle

You need to be able to...	Engineers need to be able to...
Recognize that an IAM role, not a password, is how a SageMaker notebook accesses S3	Write the IAM policy JSON and attach it to the role
Know that AWS KMS manages encryption keys	Configure key rotation schedules and grant policies
Identify that AWS PrivateLink keeps Bedrock traffic off the public internet	Configure VPC endpoints and route tables
Know that CloudTrail logs API activity and CloudWatch monitors operational health	Build CloudWatch dashboards and CloudTrail event filters
Recognize when Amazon Macie or Bedrock Guardrails is the right tool for a PII scenario	Integrate Macie findings into a remediation pipeline
Understand what AWS Audit Manager and AWS Artifact are used for	Configure Audit Manager assessments and control mappings

This is the lens to apply throughout this module: **recognize and select**, not configure and build.

PART 2: OFFICIAL TASK STATEMENT BREAKDOWN

Task Statement 5.1: Explain methods to secure AI systems

Full Text (per AIF-C01 Exam Guide v1.1): Explain methods to secure AI systems.

Plain-English Translation: Know which AWS tools and practices keep AI systems - their data, their access points, and their outputs - protected from misuse, leakage, and attack.

Specific Learner Skills: - Identify AWS services and features used to secure AI systems (IAM roles/policies/permissions; encryption; Amazon Macie; AWS PrivateLink; the AWS Shared Responsibility Model; Amazon Bedrock AgentCore Identity and Policy; Amazon Bedrock Guardrails). - Describe source citation and data origin documentation practices (data lineage, data cataloging, SageMaker Model Cards). - Describe best practices for secure data engineering (data quality assessment, privacy-enhancing technologies, data access control, data integrity). - Describe security and privacy considerations specific to AI systems (application security, threat detection, vulnerability management, infrastructure protection, prompt injection, encryption at rest and in transit, data leakage prevention, output filtering and validation, audit trails and logging for AI interactions, toxicity). - Describe hallucination detection methods and grounding techniques (RAG grounding, output validation, confidence scoring).

Exam Watch-Out: Questions often describe a *symptom* (e.g., “a customer reports the chatbot revealed another customer’s account balance”) and expect you to identify the *root cause category* (data leakage) and the *correct AWS response* (Bedrock Guardrails with PII masking, or stricter IAM scoping) - not just recognize a vocabulary term in isolation.

3 Realistic Exam Scenario Examples (question stems only): 1. “A company’s customer service chatbot, built on a foundation model, occasionally repeats sensitive account numbers from its training data in its responses. Which AWS capability would BEST help prevent this?” 2. “A security team wants to ensure that any sensitive data stored in the S3 bucket used for RAG

document ingestion is automatically discovered and flagged. Which AWS service should they use?”

3. “An organization wants to reduce the risk that a foundation model’s response is fabricated and ungrounded in real source material. Which technique addresses this risk?”

Task Statement 5.2: Recognize governance and compliance regulations for AI systems

Full Text (per AIF-C01 Exam Guide v1.1): Recognize governance and compliance regulations for AI systems.

Plain-English Translation: Know which AWS tools help organizations prove they are following the rules, and understand the internal processes that keep AI development accountable and well-managed over time.

Specific Learner Skills: - Identify AWS services and features that assist with governance and regulatory compliance (AWS Config, Amazon Inspector, AWS Audit Manager, AWS Artifact, AWS CloudTrail, AWS Trusted Advisor). - Describe data governance strategies (data lifecycles, logging, data residency, monitoring and observation, retention policies). - Describe the processes organizations should follow to maintain AI governance (policies, review cadence, review strategies, governance frameworks such as the Generative AI Security Scoping Matrix, transparency standards, team training requirements).

Exam Watch-Out: Learners frequently confuse AWS Artifact and AWS Audit Manager. AWS Artifact is where you *download AWS’s own* compliance reports (AWS already did the audit work; you just retrieve the paperwork). AWS Audit Manager is what *you* use to collect evidence about *your own* AWS environment on an ongoing basis to support your own audits. If the question is about getting a report AWS already produced, the answer is Artifact. If the question is about continuously gathering evidence of your own resource compliance, the answer is Audit Manager.

3 Realistic Exam Scenario Examples (question stems only): 1. “A healthcare company needs to download AWS’s official HIPAA compliance documentation to share with its own auditors. Which AWS service should it use?” 2. “A financial services company wants to continuously collect evidence that its AWS resources comply with internal AI governance policies, in preparation for an upcoming internal audit. Which AWS service is the BEST fit?” 3. “Which AWS service provides a centralized history of every API call made to Amazon Bedrock within an AWS account, including who made the call and when?”

PART 3: CORE CONCEPT NOTES - DOMAIN 5 DEEP DIVE

3A. The AWS Shared Responsibility Model for AI Workloads

The Shared Responsibility Model is the single most important governance concept on this exam, and it is explicitly called out in AWS’s own recommended baseline knowledge for this certification.

The core idea, in plain English: AWS is responsible for the security **of** the cloud. The customer is responsible for security **in** the cloud. AWS secures the physical data centers, the hardware, the virtualization layer, and the global network. The customer secures their data, their access configurations, their applications, and how they use the services AWS provides.

A simple analogy: think of AWS as the company that builds and maintains a secure apartment building - the locks on the front door, the fire suppression system, the structural integrity of the building itself. You, the tenant, are responsible for locking your own apartment door, deciding who gets a key, and not leaving your valuables out in the open. AWS cannot protect you from a mistake you make inside your own unit.

How it applies to specific AI services:

Amazon Bedrock (fully managed service): AWS is responsible for the underlying infrastructure that runs the foundation models, the physical security of the data centers, and the availability of the service. The customer is responsible for which models they choose to use, the prompts and data they send to those models, configuring IAM permissions for who can invoke which models, enabling and configuring Guardrails, and ensuring their own application does not expose sensitive data through poorly designed prompts.

Amazon SageMaker AI (shared, more customer control): Because SageMaker AI gives customers more control over building, training, and deploying their own models, the customer takes on more responsibility. AWS still secures the underlying infrastructure, but the customer is responsible for securing their training data, configuring network isolation for training jobs, managing IAM execution roles, encrypting model artifacts, and patching any custom container images they bring.

Custom-built ML pipelines on EC2/containers (most customer responsibility): When a customer builds their own pipeline on raw compute (EC2 instances or self-managed containers), AWS responsibility shrinks to the physical infrastructure and host-level security, while the customer takes on responsibility for the guest operating system, security patching, application code, network configuration, and all data protection measures.

The general rule of thumb for the exam: *The more “managed” the service, the more AWS takes on; the more “custom” or “self-hosted” the solution, the more the customer takes on.* Bedrock (fully managed) shifts the most responsibility to AWS. Self-hosted models on EC2 shift the most responsibility to the customer. SageMaker AI sits in between.

Exam question pattern - “Who is responsible for X in this scenario?”: When you see this pattern, ask two questions: (1) Is the item in question part of the underlying infrastructure (hardware, facilities, host OS for managed services), or is it part of what the customer configures, uploads, or controls? (2) Which service is involved, and how “managed” is it? If the question describes encrypting *customer data*, configuring *IAM permissions*, or choosing *what data to send to a model* - that is almost always the customer’s responsibility, regardless of which AI service is involved.

3B. Identity and Access Management (IAM) for AI Workloads

IAM review at the AI Practitioner level: AWS Identity and Access Management (IAM) is the AWS service that controls *who* (a person, application, or AWS service) can do *what* (specific actions) to *which* AWS resources. The four core building blocks are: - **Users:** Individual identities, typically representing a person. - **Groups:** Collections of users that share the same permissions. - **Roles:** Temporary identities that can be assumed by users, applications, or AWS services themselves (this is the building block most relevant to AI workloads). - **Policies:** JSON documents that define exactly which actions are allowed or denied on which resources.

Principle of least privilege: Grant only the minimum permissions needed to perform a task -

nothing more. For AI workloads, this means a SageMaker training job should only have access to the specific S3 bucket it needs, not every bucket in the account; a Bedrock-powered application should only be allowed to invoke the specific models it actually needs, not every model available in the service.

IAM roles for SageMaker: SageMaker AI commonly uses **execution roles** - an IAM role attached to a SageMaker notebook, training job, or endpoint that defines what that resource is allowed to do. For example, a SageMaker notebook needs an execution role that grants it permission to read training data from a specific S3 bucket and write model artifacts back to another bucket. The notebook itself does not have a username and password; it “assumes” the role to get temporary, scoped permissions.

IAM roles for Bedrock: Similarly, applications calling Amazon Bedrock use IAM roles and policies to control which users or applications can invoke which foundation models, and cross-account access can be configured so that one AWS account can grant another account permission to use specific Bedrock resources without sharing long-term credentials.

Resource-based policies: In addition to identity-based policies (attached to a user, group, or role), some AWS resources support resource-based policies attached directly to the resource itself, defining who is allowed to access that specific resource - useful for controlling cross-account access to things like S3 buckets holding training data.

Worked example - granting a SageMaker notebook access to S3: A data scientist creates a SageMaker notebook instance. Instead of embedding access keys in the notebook code (a bad practice), the notebook is launched with an attached IAM execution role. That role has a policy attached granting `s3:GetObject` and `s3:PutObject` permissions, scoped only to the specific bucket containing the training data. When the notebook code runs `boto3` calls to S3, AWS automatically uses the temporary credentials from the assumed role - no hardcoded secrets required.

Supplemental context (not officially exam-scoped): Service control policies (SCPs) are a feature of AWS Organizations used to set permission guardrails across multiple AWS accounts. AWS Organizations itself is listed as an out-of-scope service for the AIF-C01 exam guide. You may encounter SCPs mentioned in real-world AI governance discussions, but they are not part of the tested content for this certification - the exam focuses on IAM roles and policies within a single account’s context.

3C. Network Security for AI Workloads

Amazon VPC (Virtual Private Cloud): A VPC is a logically isolated, private section of the AWS Cloud where a customer can launch resources with full control over IP addressing, subnets, and routing. For AI workloads, placing training jobs, inference endpoints, and data stores inside a VPC keeps them off the public internet by default, reducing the attack surface.

VPC endpoints and AWS PrivateLink: Even resources inside a VPC sometimes need to talk to AWS services like Amazon Bedrock or Amazon SageMaker. Normally, that traffic would have to leave the VPC and cross the public internet (even if briefly, within AWS’s network) to reach the public API endpoint of the service. **AWS PrivateLink** solves this by creating a private, direct network path between your VPC and the AWS service - the traffic never traverses the public internet at all. This is explicitly named in the official exam objectives as a method to secure AI systems, so expect it to appear in exam scenarios involving sensitive data and regulatory requirements.

Why this matters: A financial services company processing customer financial data through Bedrock wants assurance that prompts and responses never travel across the public internet, even encrypted. AWS PrivateLink (accessed via a VPC endpoint) is the AWS-native answer to that requirement.

Security groups and NACLs (awareness level): Security groups act as virtual firewalls controlling inbound and outbound traffic at the instance level; network access control lists (NACLs) operate at the subnet level. For the AI Practitioner exam, you simply need to know these exist as network traffic controls - you will not be asked to configure rule sets.

SageMaker network isolation: SageMaker AI supports running training jobs with **network isolation enabled**, meaning the training container has no outbound internet access at all - it cannot make any external network calls during training. This is a meaningful security control when training on highly sensitive data, because it eliminates the risk of data being exfiltrated during the training process itself.

Why network isolation matters for sensitive data: Even if a training job's container image were compromised (for example, through a malicious dependency), network isolation would prevent that compromised code from "phoning home" or exfiltrating training data to an external destination, because there is no outbound path available.

3D. Data Security and Encryption

Encryption at rest: Protects data while it is stored - on disk, in a database, or in an S3 bucket. If someone gained unauthorized physical or low-level access to the storage media, encrypted data would be unreadable without the proper key.

Encryption in transit: Protects data while it is moving across a network - between a client application and an AI service, or between two AWS services. This is accomplished through TLS/HTTPS, which is used for all API calls to AWS AI services such as Amazon Bedrock and Amazon SageMaker by default.

Encryption at rest options, explained in plain English: - **SSE-S3:** Server-side encryption using keys that Amazon S3 manages entirely on your behalf. Simplest option; you have no key management responsibility at all. - **SSE-KMS:** Server-side encryption using keys managed through AWS Key Management Service (AWS KMS). This gives you more control - you can see who used a key, enforce permissions on the key itself, and rotate keys - while AWS still performs the actual encryption/decryption operations. - **SSE-C:** Server-side encryption where *you* supply your own encryption key with each request, and AWS uses it to encrypt/decrypt but never stores the key itself.

AWS Key Management Service (AWS KMS): A managed service for creating, storing, and controlling the cryptographic keys used to encrypt data across AWS services. For an AI Practitioner, the key fact is: KMS does not store your *data* - it manages the *keys* that lock and unlock your data.

Customer managed keys (CMK) vs. AWS managed keys vs. AWS owned keys: - **AWS owned keys:** Keys owned and managed entirely by AWS, used across many AWS accounts; the customer has no visibility or control. Lowest customer effort, lowest customer control. - **AWS managed keys:** Keys created and managed by AWS specifically for use within your account by a particular AWS service, but you can view some details (such as key rotation status) in the console. - **Customer managed keys (CMK):** Keys that *you* create, own, and fully control within AWS

KMS - you set the permissions, define the rotation schedule, and can disable or delete the key. Highest customer control, highest customer responsibility.

Encrypting training data and model artifacts: Training data stored in S3 can be encrypted using SSE-S3 or SSE-KMS. SageMaker model artifacts (the output of a training job) can similarly be encrypted at rest using a customer managed KMS key, giving the organization full control over who can decrypt and access trained model files.

Data masking and tokenization: Techniques for protecting sensitive data by replacing real values with substitute values (masking) or non-sensitive placeholder tokens (tokenization) before that data is used in an AI pipeline - reducing the risk that sensitive raw values are ever exposed to a model, a developer, or a log file.

Amazon Bedrock data handling: A frequently tested point of confusion: by default, Amazon Bedrock does **not** use customer prompts or outputs to train or improve the underlying foundation models, and customer content is not shared with the model providers for their own purposes. Data sent to Bedrock is encrypted in transit and at rest. This “no training on your data by default” behavior is an important data privacy distinction between using a foundation model through Bedrock versus some public consumer-facing chatbot products.

3E. Compliance and Regulatory Considerations for AI

What compliance means for AI workloads: Compliance for traditional IT usually focuses on how data is stored, accessed, and transmitted. For AI workloads, compliance extends further - regulators and auditors increasingly care about the AI system’s *outputs* as well: Can you explain why the model made a decision? Can you prove the training data was legally obtained? Can you demonstrate the system does not produce discriminatory outcomes?

Key frameworks at an awareness level (supplemental context for general business literacy - not all are explicitly named in the AIF-C01 task statements, but they inform the “governance and compliance regulations” objective):

- **GDPR (General Data Protection Regulation):** A European Union regulation governing how personal data is collected, processed, and stored, including a “right to erasure” that has real implications for AI training data.
- **HIPAA (Health Insurance Portability and Accountability Act):** A U.S. regulation governing the privacy and security of health information, highly relevant to any AI system processing patient data.
- **SOC 2:** An auditing standard assessing how a service organization manages data security, availability, and confidentiality - frequently referenced in AWS’s own compliance reports.
- **ISO 27001:** An international standard for information security management systems.
- **NIST AI Risk Management Framework (NIST AI RMF):** A U.S. framework providing guidance on managing risks specific to AI systems throughout their lifecycle - mapping closely to the kind of governance thinking tested in this domain.
- **EU AI Act (awareness only - not part of official AIF-C01 scope):** A European Union regulatory framework that categorizes AI systems by risk level and imposes corresponding obligations. Mentioned here only as real-world context; it is not named in the official exam objectives.

AWS compliance certifications - what they cover and what they don’t: AWS undergoes independent third-party audits across dozens of compliance programs and makes the resulting reports available through AWS Artifact. These certifications validate that **AWS’s own infrastructure and operational controls** meet a given standard. They do **not** automatically make a customer’s *application* built on top of AWS compliant - the customer must still configure their own

use of AWS services correctly, per the Shared Responsibility Model.

AWS Artifact: A no-cost, self-service portal where customers can access and download AWS’s compliance reports, certifications, and audit documentation on demand - useful when a customer’s own auditors ask for proof of AWS’s compliance posture.

The concept of AI-specific compliance: Beyond standard data protection compliance, AI systems increasingly face requirements around output auditability (can you show what the model said and why) and explainability (can you describe, in terms a regulator or customer would accept, how a decision was reached). This connects directly back to Domain 4’s transparency and explainability concepts.

Industry-specific considerations (awareness level): - **Healthcare AI:** Must address HIPAA requirements for protecting patient health information used in or generated by AI systems. - **Financial AI:** Subject to financial industry regulatory bodies (such as FINRA and the SEC in the United States), which scrutinize AI-driven decisions affecting consumers, such as credit or lending decisions.

3F. Monitoring, Logging, and Audit

AWS CloudTrail: Records a complete history of every API call and action taken within an AWS account - who did what, when, and from where. For AI workloads, CloudTrail answers questions like “Who invoked this Bedrock model on this date?” or “Was this SageMaker training job started by an authorized user?” CloudTrail is about **accountability for actions taken**.

Amazon CloudWatch: A monitoring and observability service that collects metrics, logs, and events to track the *operational health* and *performance* of resources, generating alarms when something is operating outside expected parameters. CloudWatch is about **operational health and performance**, not who-did-what auditing.

Amazon SageMaker Model Monitor: A specialized monitoring capability that continuously evaluates a deployed model’s quality in production, watching for: - **Data drift:** When the real-world data a model receives in production starts to look statistically different from the data it was trained on (for example, customer demographics shifting over time). - **Model drift:** When a model’s prediction quality degrades over time, often as a downstream effect of data drift or changes in the underlying patterns the model originally learned.

Amazon Bedrock logging: Amazon Bedrock supports logging of model invocation requests and responses, which can be sent to Amazon CloudWatch Logs or Amazon S3, enabling an organization to review exactly what prompts were sent and what responses were generated - a critical capability for auditing AI interactions and investigating potential misuse.

Why logging model inputs and outputs matters for governance: If a customer later disputes an AI-generated decision, or a regulator asks how a system behaved on a specific date, the organization needs a verifiable record of the actual prompt and the actual response - not just a description of how the system is “supposed to” behave.

Setting up alerts for anomalous AI service usage: CloudWatch alarms can be configured to trigger when unusual patterns emerge - for example, a sudden spike in Bedrock model invocations that might indicate a cost-control issue or a compromised credential being used to abuse the service.

3G. AI Governance Frameworks

What AI governance means: The complete system of policies, processes, accountability structures, and oversight mechanisms an organization puts in place to ensure AI is developed and used responsibly, consistently, and in alignment with both internal standards and external regulations.

Model governance with Amazon SageMaker:

- **SageMaker Model Registry:** A centralized catalog for versioning, cataloging, and managing trained ML models, including approval status, making it possible to track exactly which model version is approved for production use.
- **Model approval workflows:** Structured processes (often combined with the Model Registry) requiring a designated reviewer to approve a model before it can be deployed to production - adding a human governance checkpoint to the deployment pipeline.
- **SageMaker Model Cards:** Structured documentation capturing a model's intended use, training data sources, performance characteristics, and limitations - serving both transparency (Domain 4) and governance (Domain 5) purposes, since they create a documented record of model provenance.

ML lifecycle governance: The idea that every stage from data collection through deployment and ongoing monitoring should be documented and controlled - not left to informal, undocumented practices that make it impossible to reconstruct how a model came to be or whether it still performs as expected.

Data lineage and provenance: Tracking exactly where training data came from, how it was transformed, and what it was used for - essential both for debugging model behavior and for proving to a regulator or customer that data was sourced and used appropriately.

Model risk management (MRM) - awareness level, supplemental context: A formal discipline, common in regulated financial institutions, for identifying, measuring, and controlling the risks that arise from relying on models (including AI models) for business decisions. MRM is not an AWS service and is not separately named in the official AIF-C01 task statements, but understanding the *concept* helps explain why financial firms apply such rigorous governance to AI systems.

Supplemental context (not officially exam-scoped): AWS Control Tower and AWS Organizations are sometimes discussed in enterprise AI governance conversations because they help manage multiple AWS accounts at scale. However, both are explicitly listed as **out of scope** in the official AIF-C01 Exam Guide. They will not appear as correct answers on this exam, and you do not need to study their configuration details for this certification.

3H. Data Privacy and PII Protection in AI

Why AI systems create unique data privacy risks: Traditional databases store data in a predictable, queryable structure - if you control access to the database, you control access to the data. Generative AI models introduce new risks:

- **Memorization:** A model trained on data containing sensitive examples may “memorize” specific details and reproduce them verbatim later, even for users who should never see that information.
- **Output leakage:** A model might unintentionally reveal pieces of its training data, or details from a different user's conversation (if context is improperly isolated), through its generated responses.
- **Training data exposure:** If training data itself is mishandled (overly broad access, inadequate encryption), the raw sensitive data is exposed long before a model is ever deployed.

Identifying and protecting PII in AI pipelines: Personally identifiable information (PII) - data that can identify a specific individual, such as names, social security numbers, or account numbers - needs to be identified and protected at every stage: in the raw training data, in any documents used for RAG, and in the live prompts and responses flowing through a deployed application.

Amazon Macie: An ML-powered data security service that automatically discovers and classifies sensitive data - including PII - stored in Amazon S3, and generates alerts when that data is at risk. Macie is focused on **data at rest in S3**, helping organizations find sensitive data they may not even know they have (for example, in a RAG knowledge base document repository).

Amazon Bedrock Guardrails PII masking: A capability within Amazon Bedrock Guardrails that detects and redacts (masks) sensitive information - such as names, addresses, or account numbers - from both the **inputs** sent to a model and the **outputs** a model generates, in real time, as part of the live application flow.

The key distinction: Macie scans data **at rest** in storage to find out what sensitive data exists; Bedrock Guardrails PII masking acts **in real time** on the live flow of prompts and responses to prevent sensitive data from being processed or returned in the first place. They solve related but different problems and are commonly paired together.

Data retention policies for AI training data and model artifacts: Organizations should define clear policies for how long training data, fine-tuning datasets, and model artifacts are retained, balancing operational needs against privacy risk and storage cost.

The right to erasure (GDPR Article 17) and AI training data: Under GDPR, individuals can request that their personal data be deleted. This becomes complicated once that data has been used to train a model, because a trained model does not store data in a simple, deletable record the way a database does. This tension - between an individual's right to erasure and the practical difficulty of "un-training" a model - is one of the most discussed real-world AI privacy challenges, and a useful concept for understanding why data governance must happen *before* training, not just after.

3I. Threat Modeling for AI Systems

Prompt injection attacks: An attack where a malicious actor crafts input text specifically designed to manipulate an AI model into ignoring its original instructions, revealing confidential system prompts, or performing unintended actions. For example, a user might embed a hidden instruction inside a document being summarized by an AI assistant, hoping the model will follow the embedded instruction instead of summarizing normally. **Amazon Bedrock Guardrails** helps defend against prompt injection by filtering and validating both inputs and outputs against defined safety policies.

Model inversion and data extraction attacks (awareness level): Sophisticated attacks where an adversary attempts to reconstruct details of a model's training data by carefully analyzing patterns in the model's outputs - a reminder that protecting the *model itself* and the *infrastructure around it* matters, not just the original training data files.

Adversarial inputs: Inputs deliberately crafted - sometimes through tiny, almost imperceptible modifications - to cause an AI model to produce an incorrect, unexpected, or harmful output. This concept applies to both traditional ML (an altered image fooling a computer vision model) and

generative AI (a cleverly worded prompt fooling an LLM).

Supply chain risks: Using third-party foundation models, open-source libraries, or pre-trained components introduces risk if those components contain vulnerabilities, are tampered with, or are sourced from an unverified provider. Awareness of where a model or component “came from” connects back to the data lineage and provenance concepts in 3G.

Amazon Bedrock Guardrails as a defense layer: Worth repeating because it appears across multiple Domain 5 threat scenarios: Guardrails provides configurable content filters, denied topics, word filters, and PII redaction that can be applied to both the prompts going into a model and the responses coming out - making it a central AI-specific security control referenced explicitly in the official exam objectives.

Supplemental context (not officially exam-scoped): AWS WAF (Web Application Firewall) is sometimes discussed as a way to protect API endpoints, including those serving AI applications, from common web exploits. However, AWS WAF is listed as out of scope in the official AIF-C01 Exam Guide and will not appear as a correct answer on this exam.

PART 4: KEY TERMS AND DEFINITIONS - DOMAIN 5

Term	Simple Definition	Everyday Analogy	Why It Matters	Common Misunderstanding
Shared responsibility model	The division of security duties between AWS (security <i>of</i> the cloud) and the customer (security <i>in</i> the cloud)	AWS maintains the apartment building; you lock your own apartment door	Determines who must act when something goes wrong	People assume AWS handles everything; AWS only secures the infrastructure layer
IAM	The AWS service controlling who can access which resources and perform which actions	A building’s master key system, issuing different keys to different people	Foundational to every AI security scenario involving access	People think IAM is only for human users, not services and applications
IAM role	A temporary identity that a user, application, or AWS service can “assume” to get scoped permissions	A visitor badge that grants temporary, limited access	Lets services like SageMaker access other resources securely without hardcoded credentials	Confused with an IAM user, which is a permanent identity, not temporary

Term	Simple Definition	Everyday Analogy	Why It Matters	Common Misunderstanding
Principle of least privilege	Granting only the minimum permissions necessary, nothing more	Giving a contractor a key only to the room they're fixing, not the whole building	Limits the damage if credentials are compromised	People over-grant permissions "just in case," increasing risk
VPC	A logically isolated private network within AWS for deploying resources	A private, gated neighborhood within a larger city	Keeps AI workloads off the public internet by default	Assumed to be automatically encrypted; it isolates network access, not data encryption
VPC endpoint	A network connection point allowing private access to AWS services from within a VPC	A private back door directly connecting two buildings	Avoids exposing traffic to the public internet	Confused with a public-facing endpoint; it is the opposite, a private one
AWS PrivateLink	A feature enabling private connectivity between VPCs and AWS services without traversing the public internet	A dedicated underground tunnel between two buildings	Keeps Bedrock/SageMaker traffic off the public internet entirely	Assumed to be the same as a VPN; it does not require internet routing at all
Encryption at rest	Protecting stored data so it's unreadable without the correct key	A locked safe protecting documents sitting on a shelf	Protects data if storage media is improperly accessed	Assumed to also protect data in motion; it only covers stored data
Encryption in transit	Protecting data while it moves across a network	An armored truck protecting cash en route to the bank	Protects data from interception during transmission	Assumed to make data permanently secure; it only protects the trip, not storage
SSE-S3	Server-side encryption with keys fully managed by Amazon S3	The hotel manages all the room keys for you	Simplest encryption option, no key management burden	Assumed to give equal control over keys as SSE-KMS; it does not

Term	Simple Definition	Everyday Analogy	Why It Matters	Common Misunderstanding
SSE-KMS	Server-side encryption using keys managed through AWS KMS, giving more visibility and control	You control who gets a copy of the room key, hotel still opens the door	Allows tracking key usage and setting permissions on keys	Confused with SSE-C; KMS still performs the encryption, you don't supply the key per request
AWS KMS	A managed service for creating, storing, and controlling encryption keys	The locksmith and key-management office for the whole organization	Central to managing how data is encrypted across AI services	Assumed to store the actual data; it manages keys, not the data itself
Customer managed key (CMK)	An encryption key that the customer creates and fully controls within AWS KMS	A safe whose combination only you know and can change	Gives full control over rotation, permissions, and deletion of the key	Assumed to be the default; AWS managed keys are the default in many services
Data masking	Replacing sensitive data values with substitute values to protect privacy	Redacting a document with a black marker before sharing it	Reduces exposure of raw sensitive data in AI pipelines	Confused with encryption; masking does not necessarily allow reversal, encryption does
AWS CloudTrail	Logs every API call and action taken within an AWS account	The building's sign-in log: who entered, when, and which door they used	Provides accountability for who did what in an AI system	Confused with CloudWatch, which tracks performance, not actions
Amazon CloudWatch	Monitors operational metrics, logs, and generates alarms for resource health	The building's smoke detectors and thermostat dashboard	Detects operational issues with AI workloads in real time	Confused with CloudTrail, which logs actions, not performance
SageMaker Model Monitor	Continuously tracks deployed model quality, watching for drift	A factory quality-control inspector checking output consistency over time	Detects when a production model starts performing worse	Assumed to fix the model automatically; it detects and alerts, it does not retrain on its own

Term	Simple Definition	Everyday Analogy	Why It Matters	Common Misunderstanding
Data drift	When real-world input data starts statistically differing from training data	Training to bake with summer produce, then being handed winter produce	Signals that a model may need retraining or review	Confused with model drift, which is about output/performance quality, not input data
Model drift	When a model's prediction quality degrades over time	A once-sharp recipe that stops tasting right as ingredients quietly change	Signals declining business value of a deployed model	Assumed to be caused only by bugs; it's often caused by gradual data drift
Amazon Macie	An ML-powered service that discovers and classifies sensitive data in S3	A specialist who scans every filing cabinet in a warehouse for confidential folders	Finds PII you may not know exists in a data lake or RAG repository	Assumed to monitor live AI conversations; it scans data at rest, not real-time prompts
PII	Personally identifiable information - data that can identify a specific person	A passport, containing details that point to exactly one person	Central to almost every AI privacy and compliance scenario	Assumed to mean only names/SSNs; it includes any data uniquely identifying someone
AI governance	The full system of policies, processes, and oversight ensuring responsible AI use	A company's overall rulebook and oversight committee for how it builds anything	The umbrella concept tying together compliance, security, and responsible AI	Confused with compliance; governance is broader than meeting a specific external rule
Model governance	Governance practices applied specifically to ML model lifecycle management	A library's cataloging and checkout-approval system, but for models	Ensures only approved, tracked model versions reach production	Assumed to be automatic; it requires deliberate registry and approval processes

Term	Simple Definition	Everyday Analogy	Why It Matters	Common Misunderstanding
Model registry	A centralized catalog for versioning and managing trained models	A library's card catalog tracking every book and its current status	Tracks which model version is approved for production use	Confused with a model card; the registry tracks versions, the card documents behavior
Data lineage	Tracking where data came from and how it was transformed over time	A grocery item's farm-to-shelf paper trail	Supports auditability and trust in training data sources	Assumed to be the same as data cataloging; lineage tracks history, cataloging organizes inventory
Compliance	Meeting a specific external law, regulation, or standard	Passing a specific health inspection for a restaurant	A measurable, specific outcome organizations must demonstrate	Confused with governance, which is the broader system that helps achieve compliance
AWS Artifact	A self-service portal for downloading AWS's own compliance reports	A public records office where you can request official certificates	Lets customers prove AWS's compliance posture to their own auditors	Confused with Audit Manager, which is for the customer's own ongoing evidence collection
GDPR	An EU regulation governing personal data collection, processing, and storage	A strict house rule about how a host may use and must dispose of guest information	Affects how organizations handle EU residents' data in AI training and use	Assumed to apply only to EU companies; it can apply to any company processing EU residents' data
HIPAA	A U.S. law governing privacy and security of health information	A hospital's strict confidentiality oath, codified into law	Directly relevant to any AI system touching patient health data	Assumed to apply to all healthcare-adjacent data; it specifically covers protected health information

Term	Simple Definition	Everyday Analogy	Why It Matters	Common Misunderstanding
NIST AI RMF	A U.S. framework for managing risks across the AI system lifecycle	A safety inspection checklist designed specifically for AI projects	Provides structured guidance for AI-specific risk management	Assumed to be a law; it is a voluntary framework, not a binding regulation
Prompt injection	An attack manipulating an AI model through crafted input to bypass intended behavior	Slipping a forged note into someone's instructions hoping they'll follow it instead	A foundational AI-specific security risk unique to generative AI	Assumed to require advanced hacking skills; it can be attempted with plain natural language
Adversarial input	Input deliberately crafted to cause a model to produce an incorrect or harmful output	A magic trick using subtle misdirection to fool the eye	Demonstrates that AI models can be deliberately fooled, not just accidentally wrong	Assumed to only apply to images; it applies to text and other modalities too
Audit trail	A chronological record of actions and events for accountability and review	A flight's black box recording, used to reconstruct what happened	Essential for investigating incidents and proving compliance after the fact	Assumed to be optional; for regulated AI use cases it is often a requirement
Amazon Bedrock logging	The capability to log Bedrock model invocation requests and responses	A call center recording every customer service call for quality review	Provides the raw evidence needed for AI governance and incident investigation	Assumed to be enabled by default; it must be explicitly configured
AWS Control Tower (out of scope)	A service for setting up and governing a multi-account AWS environment	A corporate headquarters establishing rules for every branch office	Useful real-world context, but not tested on the AIF-C01 exam	Some learners assume it's exam-relevant because it sounds governance-related; it is explicitly out of scope

PART 5: COMPARISON TABLES - DOMAIN 5

Table 1: AWS Shared Responsibility - Amazon Bedrock vs. SageMaker AI vs. Self-Managed (EC2/Containers)

Responsibility Area	Amazon Bedrock	Amazon SageMaker AI	Self-Managed on EC2/Containers
Physical data center security	AWS	AWS	AWS
Underlying hardware and host infrastructure	AWS	AWS	AWS (hardware only)
Guest operating system and patching	AWS (fully managed)	Shared - AWS manages some, customer manages custom containers	Customer
Model hosting infrastructure	AWS	Shared - AWS manages the platform, customer configures instances	Customer (fully self-built)
Training data protection and encryption	Customer	Customer	Customer
IAM configuration (who can access what)	Customer	Customer	Customer
Application code and prompt design	Customer	Customer	Customer
Network configuration (VPC, PrivateLink)	Customer (opt-in configuration)	Customer (opt-in configuration)	Customer (full responsibility)
Guardrails / content filtering configuration	Customer (enables and configures Bedrock Guardrails)	Customer (must build or integrate own controls)	Customer (must build entirely from scratch)
Overall level of customer responsibility	Lowest	Medium	Highest

Table 2: Encryption Options - SSE-S3 vs. SSE-KMS vs. Client-Side Encryption

Feature	SSE-S3	SSE-KMS	Client-Side Encryption
Who manages the encryption keys	Amazon S3 (fully automatic)	AWS KMS (customer can use AWS managed or customer managed keys)	The customer, before data is ever sent to AWS
Visibility into key usage	None	Detailed (via CloudTrail logging of KMS key usage)	Full (entirely under customer control)

Feature	SSE-S3	SSE-KMS	Client-Side Encryption
Setup complexity	Lowest	Moderate	Highest
Typical AI workload use case	General-purpose storage of non-sensitive training assets	Sensitive training data, model artifacts, regulated workloads needing audit trails	Highly sensitive data requiring encryption before it ever leaves customer systems
Best fit when...	Simplicity is the priority and data sensitivity is low to moderate	You need to control and audit who can use the encryption key	You cannot allow AWS to ever see the plaintext data

Table 3: AWS CloudTrail vs. Amazon CloudWatch vs. SageMaker Model Monitor

Feature	AWS CloudTrail	Amazon CloudWatch	SageMaker Model Monitor
What it tracks	API calls and account activity (who did what, when)	Operational metrics, logs, and events (system health and performance)	Production model quality (data drift, model drift, prediction quality)
Primary question it answers	“Who invoked this Bedrock model and when?”	“Is this AI service running normally right now?”	“Is this deployed model’s prediction quality degrading?”
When to use it	Security investigations, compliance audits, accountability tracking	Real-time operational monitoring and alerting	Ongoing ML-specific quality assurance in production
What alerts it generates	Can trigger alerts via integration with Cloud-Watch/EventBridge on suspicious activity patterns	Alarms on metric thresholds (latency, error rates, resource usage)	Alerts when drift or quality metrics cross defined thresholds
AI-specific relevance	Logs Bedrock/SageMaker API invocations for audit trails	Monitors latency, throttling, and errors for AI service calls	Purpose-built for monitoring ML model behavior over time

Table 4: Amazon Macie vs. Amazon Bedrock Guardrails PII Masking

Feature	Amazon Macie	Bedrock Guardrails PII Masking
What it does	Discovers and classifies sensitive data stored in Amazon S3	Detects and redacts sensitive data in real-time model inputs and outputs
Data state protected	Data at rest (stored files)	Data in active use (live prompts and responses)
When to use it	Auditing a data lake or RAG document repository for hidden PII	Preventing PII from ever reaching or leaving a foundation model during live use
Input vs. output protection	Neither - it scans stored data, not live conversation flow	Both - can mask PII in what goes into the model and what comes out
Typical pairing	Used before/alongside data ingestion into a knowledge base	Used continuously as part of a live Bedrock-powered application

Table 5: AI Governance Tools - SageMaker Model Registry vs. Model Cards vs. AWS Audit Manager

Feature	SageMaker Model Registry	SageMaker Model Cards	AWS Audit Manager
Primary purpose	Version and catalog trained models, manage approval status	Document a model’s intended use, training data, performance, and limitations	Continuously collect evidence of AWS resource compliance
What it produces	A tracked inventory of model versions and their deployment status	A structured, shareable document describing one specific model	Audit-ready evidence reports mapped to compliance frameworks
Who typically uses it	ML engineers and model approvers	Data scientists, risk teams, and external stakeholders needing model transparency	Compliance teams and auditors
Scope	Operational model lifecycle management	Single-model documentation and transparency	Account-wide and ongoing compliance evidence gathering

Table 6: Compliance Frameworks Comparison

Framework	What It Covers	AI Relevance	AWS Support
GDPR	Personal data collection, processing, storage, and individual rights (including erasure) for EU residents' data	Raises hard questions about deleting personal data once it has been used to train a model	AWS provides GDPR-related compliance documentation via AWS Artifact; customer remains responsible for application-level compliance
HIPAA	Privacy and security of protected health information in the U.S.	Directly governs AI systems processing patient data (for example, clinical summarization tools)	Many AWS services, including select AI/ML services, support HIPAA-eligible workloads when properly configured; compliance reports available via AWS Artifact
SOC 2	Security, availability, and confidentiality controls of a service organization	Demonstrates AWS's own operational control rigor, which underpins trust in AI services built on AWS	SOC 2 reports available to customers through AWS Artifact
NIST AI RMF	Risk management guidance across the AI system lifecycle (govern, map, measure, manage)	Provides a structured way to think about AI-specific risks beyond traditional data security	Not an AWS certification itself, but aligns conceptually with AWS governance tooling (Audit Manager, Config, CloudTrail)

PART 6: 25 DOMAIN 5 PRACTICE QUESTIONS

Beginner Questions (1-10)

Question 1 (Multiple Choice) Under the AWS Shared Responsibility Model, which of the following is AWS always responsible for?

A. Configuring IAM permissions for a customer's application
 B. The physical security of the data centers hosting AWS services
 C. Encrypting a customer's training data before upload
 D. Designing a customer's VPC network architecture

Question 2 (Multiple Choice) A company wants to ensure that traffic between its VPC and Amazon Bedrock never crosses the public internet. Which AWS feature should it use?

A. Amazon CloudFront B. AWS PrivateLink C. AWS Trusted Advisor D. AWS Config

Question 3 (Multiple Choice) Which AWS service automatically discovers and classifies sensitive data, such as PII, stored in Amazon S3?

A. Amazon Inspector B. AWS Audit Manager C. Amazon Macie D. AWS Config

Question 4 (Multiple Choice) What is the primary purpose of AWS CloudTrail?

A. Monitoring the operational health of AWS resources B. Logging API calls and account activity for auditing purposes C. Detecting bias in machine learning models D. Encrypting data at rest in Amazon S3

Question 5 (Multiple Choice) Which term describes an attack where crafted input text attempts to manipulate an AI model into ignoring its original instructions?

A. Model inversion B. Data drift C. Prompt injection D. Adversarial training

Question 6 (Multiple Choice) A customer needs to download AWS's official SOC 2 compliance report to share with their internal audit team. Which AWS service should they use?

A. AWS Audit Manager B. AWS Artifact C. AWS Config D. AWS Trusted Advisor

Question 7 (Multiple Choice) What does "encryption at rest" protect?

A. Data while it travels across a network B. Data while it is stored, such as in a database or S3 bucket C. Data while a user is actively typing it into a chatbot D. The identity of users accessing a system

Question 8 (Multiple Choice) Which IAM concept ensures that a resource is granted only the minimum permissions it needs to perform its task?

A. Resource-based policy B. Principle of least privilege C. Customer managed key D. Service control policy

Question 9 (Multiple Choice) A SageMaker training job is configured with network isolation enabled. What does this mean?

A. The training job can only access resources within a specific AWS Region B. The training job has no outbound internet access during training C. The training job automatically encrypts all output with a customer managed key D. The training job can only be started by an IAM administrator

Question 10 (Multiple Choice) Which of the following best describes the difference between Amazon CloudWatch and AWS CloudTrail?

A. CloudWatch tracks API activity; CloudTrail tracks performance metrics B. CloudWatch tracks operational performance; CloudTrail tracks API activity and account actions C. They are two names for the same service D. CloudWatch is for governance; CloudTrail is for security only

Intermediate Questions (11-20)

Question 11 (Multiple Choice) A company is using Amazon SageMaker AI to train a custom model on sensitive customer data. Under the Shared Responsibility Model, who is responsible for encrypting that training data?

A. AWS, because SageMaker is a managed service B. The customer, regardless of which AI service is used C. AWS, only if the customer requests it D. Neither party; encryption is optional

Question 12 (Multiple Response - select TWO) Which TWO of the following are valid encryption-at-rest options available for protecting data in Amazon S3?

A. SSE-S3 B. AWS PrivateLink C. SSE-KMS D. AWS CloudTrail E. SageMaker Model Monitor

Question 13 (Multiple Choice) A retail company notices that a deployed recommendation model's predictions have become noticeably less accurate over the past few months, even though no code changes were made. Which AWS capability would help diagnose this issue?

A. AWS Config B. SageMaker Model Monitor C. Amazon Macie D. AWS Artifact

Question 14 (Multiple Choice) A healthcare organization wants to prevent a Bedrock-powered clinical assistant from ever returning a patient's full social security number in its generated response, even if that number appears somewhere in the retrieved context. Which capability directly addresses this?

A. SageMaker Model Cards B. Amazon Bedrock Guardrails PII masking C. AWS CloudTrail D. Amazon Inspector

Question 15 (Multiple Choice) Which statement correctly distinguishes AWS Artifact from AWS Audit Manager?

A. AWS Artifact collects ongoing evidence of a customer's resource compliance; Audit Manager provides AWS's own compliance reports B. AWS Artifact provides AWS's own compliance reports for download; Audit Manager helps customers collect ongoing evidence of their own compliance C. They are interchangeable services with no meaningful difference D. AWS Artifact is for network security; Audit Manager is for data security

Question 16 (Ordering) Place the following data governance activities in the order they would typically occur across a model's data lifecycle, from earliest to latest:

A. Defining a data retention policy for training data after a model is decommissioned B. Collecting and curating the raw training dataset C. Logging data access during active model training D. Establishing data residency requirements before any data collection begins

Question 17 (Multiple Choice) A company wants a centralized, version-controlled catalog of every trained model, including which version is currently approved for production deployment. Which AWS capability best fits this need?

A. SageMaker Model Cards B. SageMaker Model Registry C. Amazon Macie D. AWS Config

Question 18 (Multiple Response - select TWO) Which TWO of the following are examples of AI-specific security risks that go beyond traditional application security?

A. SQL injection against a relational database B. Prompt injection against a foundation model C. Model inversion attacks attempting to extract training data patterns D. A misconfigured load balancer health check E. An expired TLS certificate

Question 19 (Multiple Choice) Which AWS service would BEST help an organization continuously evaluate whether its AWS resource configurations comply with a defined AI governance policy, in preparation for an internal audit?

A. AWS Artifact B. AWS Audit Manager C. Amazon CloudWatch D. Amazon Macie

Question 20 (Matching) Match each AWS service on the left with its PRIMARY function on the right.

Service	Function
1. Amazon Macie	A. Logs API calls and account activity
2. AWS KMS	B. Discovers sensitive data in S3
3. AWS CloudTrail	C. Manages encryption keys
4. AWS PrivateLink	D. Provides private connectivity to AWS services

Exam-Ready Questions (21-25)

Question 21 (Multiple Choice) A multinational company must ensure that EU customer data processed by its Bedrock-powered support chatbot is handled in a way that respects an individual's right to request deletion of their personal data. Which concept BEST describes the compliance challenge this creates?

A. The difficulty of applying GDPR's right to erasure to data that has already influenced a trained model
B. The need to encrypt data in transit using TLS
C. The requirement to use SSE-KMS instead of SSE-S3
D. The need to enable VPC network isolation

Question 22 (Multiple Response - select THREE) A company is designing security controls for a new Bedrock-based application that will process sensitive financial documents. Which THREE of the following should be part of its security approach?

A. Configure Amazon Bedrock Guardrails to filter and mask sensitive content
B. Use AWS PrivateLink to keep traffic off the public internet
C. Disable all IAM permissions to simplify access
D. Encrypt data at rest using SSE-KMS with a customer managed key
E. Avoid logging any model inputs or outputs to reduce storage costs

Question 23 (Multiple Choice) A model deployed in production was trained on a dataset reflecting customer behavior from two years ago. Over the past six months, customer behavior patterns have shifted considerably due to a major market change, and the model's predictions are increasingly inaccurate as a result. Which term most precisely describes the underlying cause of this scenario?

A. Prompt injection
B. Data drift
C. Adversarial input
D. Encryption at rest failure

Question 24 (Ordering) A company is responding to a regulator's request to demonstrate how its AI governance program works end-to-end. Place the following steps in the most logical sequence to present this story, from foundational policy through ongoing verification:

A. Continuously monitor AWS resource compliance using AWS Audit Manager
B. Establish AI governance policies and a review cadence
C. Log all model invocations using Amazon Bedrock logging integrated with CloudWatch
D. Retrieve relevant AWS compliance certifications from AWS Artifact to support the audit

Question 25 (Multiple Choice) A company self-hosts an open-source foundation model on Amazon EC2 instances within a custom container, rather than using Amazon Bedrock. Compared to using Amazon Bedrock, which statement BEST describes the security responsibility implications?

A. AWS takes on more security responsibility because EC2 is a core AWS service
B. The customer takes on significantly more security responsibility, including guest OS patching and container security
C. There is no difference in responsibility between Bedrock and self-hosted EC2 deployments
D. AWS automatically applies Bedrock Guardrails to all EC2-hosted models

Answer Key and Rationale

Q1: B. AWS is always responsible for physical data center security regardless of which service or configuration choice the customer makes. A, C, and D are all customer responsibilities under the Shared Responsibility Model.

Q2: B. AWS PrivateLink provides private connectivity to AWS services like Bedrock without traversing the public internet. CloudFront is a CDN, Trusted Advisor gives best-practice recommendations, and Config tracks resource configuration - none provide private network connectivity.

Q3: C. Amazon Macie is purpose-built to discover and classify sensitive data, including PII, in Amazon S3. Inspector scans compute resources for vulnerabilities; Audit Manager and Config focus on compliance/configuration tracking, not data discovery.

Q4: B. CloudTrail's defining purpose is logging API calls and account activity for auditing and accountability. CloudWatch (not listed) handles operational monitoring; Clarify (not listed) handles bias detection; KMS (not listed) handles encryption.

Q5: C. Prompt injection is the term for crafted input designed to manipulate model behavior away from its intended instructions. Model inversion is about extracting training data patterns; data drift is a data quality concept unrelated to attacks; adversarial training is a defensive ML technique, not an attack.

Q6: B. AWS Artifact is the self-service portal for downloading AWS's own compliance reports, including SOC 2 reports. Audit Manager is for collecting the customer's own ongoing compliance evidence, not downloading AWS's existing reports.

Q7: B. Encryption at rest protects stored data. Encryption in transit (not B) protects data on the move; user identity protection is an IAM concern, not an encryption concern.

Q8: B. The principle of least privilege specifically means granting the minimum permissions necessary. A resource-based policy is a mechanism for granting access, not a principle about scope; a CMK is an encryption concept; an SCP is an Organizations-level guardrail concept (out of scope for this exam).

Q9: B. Network isolation for a SageMaker training job means the training container has no outbound internet access during the training process, reducing data exfiltration risk. It does not relate to Region restriction, automatic encryption, or who can start the job.

Q10: B. CloudWatch tracks operational performance and health; CloudTrail tracks who did what via API activity. They serve different, complementary purposes - not the same service, and not domain-restricted as suggested in D.

Q11: B. Encrypting training data is always the customer's responsibility under the Shared Responsibility Model, regardless of which AI service (SageMaker, Bedrock, or otherwise) is being used. AWS secures the infrastructure; the customer secures their data.

Q12: A and C. SSE-S3 and SSE-KMS are both valid S3 encryption-at-rest options. PrivateLink is a networking feature, CloudTrail is a logging service, and Model Monitor is an ML quality-monitoring tool - none are encryption options.

Q13: B. A decline in prediction accuracy over time with no code changes is a classic symptom of model drift (often driven by underlying data drift), which SageMaker Model Monitor is specifically designed to detect. Config tracks resource configuration; Macie discovers sensitive data; Artifact provides compliance reports - none diagnose model quality decline.

Q14: B. Bedrock Guardrails PII masking is specifically designed to detect and redact sensitive data such as SSNs from both inputs and outputs in real time. Model Cards document model behavior but don't actively redact data; CloudTrail logs activity but doesn't filter content; Inspector scans compute vulnerabilities, unrelated to PII in model output.

Q15: B. AWS Artifact provides AWS's own existing compliance reports for download. AWS Audit Manager helps customers continuously collect evidence of their own resource compliance. Option A reverses the two services' functions.

Q16: D, B, C, A. Data residency requirements should be established before data collection begins (D); then raw data is collected and curated (B); access is logged during active use, including training (C); and retention policy decisions for decommissioning come after the model's active life (A).

Q17: B. The SageMaker Model Registry is specifically designed for versioning and tracking model approval status for deployment. Model Cards document behavior and limitations for a single model rather than tracking version/approval status across many models.

Q18: B and C. Prompt injection and model inversion are AI-specific risks introduced by generative and predictive AI systems respectively. SQL injection, misconfigured load balancers, and expired certificates are traditional IT/application security concerns that predate AI and are not unique to AI systems.

Q19: B. AWS Audit Manager is designed for continuous, ongoing evidence collection against compliance frameworks and internal policies. AWS Artifact provides static AWS-produced reports rather than continuous evaluation of the customer's own resources. CloudWatch and Macie serve operational monitoring and data discovery purposes, respectively, not compliance evidence collection.

Q20: 1-B, 2-C, 3-A, 4-D. Macie discovers sensitive data in S3; KMS manages encryption keys; CloudTrail logs API activity; PrivateLink provides private connectivity to AWS services.

Q21: A. This question tests the well-known real-world tension between GDPR's right to erasure and the practical difficulty of removing a specific individual's influence from an already-trained model - a governance and compliance concept, not an encryption or networking concept (which rules out B, C, and D).

Q22: A, B, and D. Configuring Guardrails for content filtering/masking, using PrivateLink for private connectivity, and encrypting data at rest with a customer managed KMS key are all sound security practices for sensitive financial data. Disabling IAM permissions (C) and avoiding all logging (E) would severely weaken security and auditability - the opposite of good practice.

Q23: B. This describes data drift: the statistical characteristics of real-world input data have shifted away from what the model was originally trained on, leading to degraded prediction quality. It is not an attack (ruling out prompt injection and adversarial input) and is unrelated to encryption.

Q24: B, C, A, D. The logical governance narrative starts with establishing policy and review cadence (B), then implementing logging of actual AI interactions (C), then continuously monitoring compliance with Audit Manager (A), and finally supplementing the story with AWS's own compliance certifications from Artifact (D) to round out the audit response.

Q25: B. Self-hosting on EC2 shifts substantially more responsibility to the customer - including guest operating system patching, container security, and infrastructure-level protections that Bedrock, as a fully managed service, would otherwise handle. AWS's responsibility on EC2 is limited to the underlying hardware and host infrastructure, not the guest environment.

PART 7: 30 DOMAIN 5 FLASHCARDS

Format: Front (term or question) / Back (definition/answer + context) / Exam Tip

Terminology Cards (1-8)

Card 1 Front: What is the AWS Shared Responsibility Model? Back: The division of security duties where AWS secures the cloud (infrastructure, hardware, facilities) and the customer secures what they put in the cloud (data, access configuration, applications). Exam Tip: If a question asks "who is responsible for X," ask whether X is infrastructure (AWS) or data/configuration/access (customer).

Card 2 Front: What is the principle of least privilege? Back: Granting only the minimum permissions necessary for a user, role, or service to perform its task - nothing more. Exam Tip: Expect this phrase to appear as the "best practice" answer choice in IAM-related scenario questions.

Card 3 Front: What is the difference between encryption at rest and encryption in transit? Back: Encryption at rest protects stored data; encryption in transit protects data while it moves across a network. Exam Tip: TLS/HTTPS = in transit. SSE-S3/SSE-KMS = at rest. Don't mix these up.

Card 4 Front: What is SSE-KMS? Back: Server-side encryption for S3 using keys managed through AWS KMS, giving the customer visibility and control over key usage and permissions. Exam Tip: SSE-KMS adds auditability and control over SSE-S3, at the cost of a bit more setup.

Card 5 Front: What is a customer managed key (CMK)? Back: An AWS KMS encryption key that the customer creates, owns, and fully controls, including rotation and permission settings. Exam Tip: "Highest customer control" = CMK. "Zero customer effort" = AWS owned key.

Card 6 Front: What is data drift? Back: When the real-world data a model sees in production becomes statistically different from the data it was originally trained on. Exam Tip: Data drift is about the INPUT data changing; model drift is about the OUTPUT quality declining.

Card 7 Front: What is prompt injection? Back: An AI-specific attack where crafted input attempts to manipulate a model into ignoring its original instructions or revealing confidential information. Exam Tip: This is a generative-AI-specific risk - it doesn't exist in traditional, non-AI software in the same way.

Card 8 Front: What is an audit trail? Back: A chronological record of actions and events that supports accountability, investigation, and compliance verification after the fact. Exam Tip: CloudTrail logs and Bedrock invocation logging are the AWS-native ways to create an audit trail for AI systems.

AWS Service Identification Cards (9-18)

Card 9 Front: Which AWS service logs every API call made within an account? Back: AWS CloudTrail. Exam Tip: CloudTrail = “who did what, when.” If the scenario is about accountability for actions, it’s CloudTrail.

Card 10 Front: Which AWS service monitors operational performance metrics and triggers alarms? Back: Amazon CloudWatch. Exam Tip: CloudWatch = “is the system healthy right now.” Don’t confuse with CloudTrail’s accountability focus.

Card 11 Front: Which AWS service discovers and classifies sensitive data stored in Amazon S3? Back: Amazon Macie. Exam Tip: Macie scans data AT REST. If the scenario is about live prompt/response content, think Bedrock Guardrails instead.

Card 12 Front: Which AWS service manages encryption keys used to protect data across AWS services? Back: AWS Key Management Service (AWS KMS). Exam Tip: KMS manages KEYS, not the data itself. Don’t confuse it with Secrets Manager, which manages credentials.

Card 13 Front: Which AWS feature provides private connectivity between a VPC and AWS services like Bedrock or SageMaker, avoiding the public internet? Back: AWS PrivateLink. Exam Tip: If the scenario specifically says “avoid the public internet,” PrivateLink is almost always the answer.

Card 14 Front: Which AWS service provides a self-service portal for downloading AWS’s own compliance reports? Back: AWS Artifact. Exam Tip: Artifact = download AWS’s existing reports. Don’t confuse with Audit Manager (your own ongoing evidence).

Card 15 Front: Which AWS service helps continuously collect evidence of your own AWS resource compliance for audits? Back: AWS Audit Manager. Exam Tip: Audit Manager = ongoing, customer-side evidence gathering, not pre-existing AWS reports.

Card 16 Front: Which SageMaker capability continuously monitors a deployed model for data drift and model drift? Back: Amazon SageMaker Model Monitor. Exam Tip: If the scenario describes declining prediction quality over time in production, Model Monitor is the answer.

Card 17 Front: Which Bedrock capability filters content, restricts topics, and masks PII in real-time model inputs and outputs? Back: Amazon Bedrock Guardrails. Exam Tip: Guardrails appears in BOTH Domain 4 (responsible AI) and Domain 5 (security) contexts - know both angles.

Card 18 Front: Which AWS service provides real-time, automated best-practice recommendations across cost, security, performance, and fault tolerance? Back: AWS Trusted Advisor. Exam Tip: Trusted Advisor gives automated checks; the Well-Architected Tool is a structured, human-led review process - know the difference.

Scenario Cards (19-25)

Card 19 Front: A company wants to prevent sensitive customer data from appearing in Bedrock model responses. What should they use? Back: Amazon Bedrock Guardrails with PII masking enabled, to redact sensitive information from both inputs and outputs in real time. Exam Tip: “Prevent sensitive data from appearing in OUTPUT” is a strong signal for Guardrails, not Macie.

Card 20 Front: A company needs to know whether sensitive data already exists somewhere in their S3-based knowledge base before they build a RAG application on top of it. What should they

use? Back: Amazon Macie, to scan and classify sensitive data already at rest in S3. Exam Tip: “Already exists in storage” = Macie. “Live, in-flight prompts/responses” = Guardrails.

Card 21 Front: An auditor asks a company to prove that AWS’s own infrastructure meets SOC 2 standards. What should the company provide? Back: A SOC 2 report retrieved from AWS Artifact. Exam Tip: Whenever the request is to PROVE something about AWS itself (not the customer’s own setup), think Artifact.

Card 22 Front: A SageMaker notebook needs to read training data from a specific S3 bucket without hardcoded credentials. How should this be configured? Back: Attach an IAM execution role to the notebook, with a policy scoped to that specific S3 bucket. Exam Tip: “No hardcoded credentials” + “AWS service needs access to another AWS service” = IAM role, not IAM user.

Card 23 Front: A financial company wants assurance that prompts sent to Bedrock never cross the public internet, even encrypted. What should they configure? Back: A VPC endpoint using AWS PrivateLink for Amazon Bedrock. Exam Tip: “Never cross the public internet” is the PrivateLink trigger phrase - even if TLS encryption is already in place.

Card 24 Front: A company’s deployed fraud-detection model has been getting noticeably less accurate over the past quarter, with no code changes made. What’s the most likely cause, and how would they detect it? Back: Likely data drift or model drift; detected using Amazon SageMaker Model Monitor. Exam Tip: “No code changes, but performance is declining” is the classic drift scenario pattern.

Card 25 Front: A company suspects a user tried to manipulate their AI assistant into revealing its system prompt through carefully worded input. What is this attack called, and what AWS tool helps defend against it? Back: Prompt injection; defended against using Amazon Bedrock Guardrails. Exam Tip: “Trying to get the model to reveal its instructions” is a textbook prompt injection / prompt exposure scenario.

Comparison Cards (26-30)

Card 26 Front: What’s the difference between AWS CloudTrail and Amazon CloudWatch for AI workload monitoring? Back: CloudTrail logs WHO did WHAT (API/account activity, for auditing); CloudWatch monitors operational HEALTH and PERFORMANCE (metrics, logs, alarms). Exam Tip: Accountability = CloudTrail. Operational health = CloudWatch.

Card 27 Front: What’s the difference between Amazon Macie and Bedrock Guardrails PII masking? Back: Macie scans data AT REST in S3 to discover sensitive data; Guardrails masks PII in LIVE, real-time prompts and responses. Exam Tip: Storage scanning = Macie. Live conversation flow = Guardrails.

Card 28 Front: What’s the difference between AWS Artifact and AWS Audit Manager? Back: Artifact = download AWS’s own pre-existing compliance reports. Audit Manager = continuously collect evidence of YOUR OWN resource compliance. Exam Tip: “AWS already did the work” = Artifact. “We need to keep proving our own compliance” = Audit Manager.

Card 29 Front: What’s the difference between SSE-S3 and SSE-KMS? Back: SSE-S3 uses keys fully and automatically managed by S3 with no customer visibility; SSE-KMS uses AWS KMS keys, giving the customer visibility into key usage and finer permission control. Exam Tip: Need to track/audit who used the key? SSE-KMS. Just need basic encryption with zero setup? SSE-S3.

Card 30 Front: What's the difference between data drift and model drift? Back: Data drift = the INPUT data a model sees in production statistically differs from its training data. Model drift = the model's OUTPUT/prediction quality has degraded over time. Exam Tip: Data drift is often the CAUSE; model drift is often the resulting EFFECT.

PART 8: DOMAIN 5 ONE-PAGE CHEAT SHEET

AWS Shared Responsibility Model for AI Services

AWS Is Responsible For	Customer Is Always Responsible For
Physical data center security	Their own data and its encryption
Underlying hardware and host infrastructure	IAM configuration (who can access what)
Global network infrastructure	Application code and prompt design
Service availability (per the managed service)	Choosing and configuring Guardrails
Patching the host layer for fully managed services (e.g., Bedrock)	Network configuration choices (VPC, PrivateLink opt-in)
	Guest OS patching for self-hosted/EC2 deployments

Top 10 Security Concepts for AI Practitioners

1. Shared Responsibility Model - AWS secures the cloud; you secure what's in it.
2. Least privilege - grant the minimum access necessary, always.
3. Encryption at rest vs. in transit - know which protects what.
4. IAM roles (not users) connect AI services to other AWS resources.
5. AWS PrivateLink keeps sensitive traffic off the public internet.
6. Prompt injection is a uniquely generative-AI security risk.
7. Macie finds sensitive data already in storage; Guardrails protects live conversations.
8. CloudTrail = accountability; CloudWatch = operational health.
9. Model Monitor catches data drift and model drift before they cause real damage.
10. AWS Artifact gives you AWS's compliance proof; Audit Manager builds your own.

Security Services at a Glance

Service	One-Line Purpose
IAM	Controls who can do what to which resources
AWS KMS	Manages encryption keys
Amazon Macie	Discovers sensitive data in S3
AWS PrivateLink	Provides private connectivity to AWS services
AWS CloudTrail	Logs API calls and account activity
Amazon CloudWatch	Monitors operational performance and health
SageMaker Model Monitor	Detects data drift and model drift in production
Amazon Bedrock Guardrails	Filters content and masks PII in real time
AWS Config	Tracks resource configuration compliance

Service	One-Line Purpose
AWS Audit Manager	Continuously collects compliance evidence
AWS Artifact	Provides AWS's own compliance reports
AWS Trusted Advisor	Gives automated best-practice recommendations
Amazon Inspector	Scans compute workloads for vulnerabilities

Domain 5 Vocabulary One-Liners

- **Compliance** = meeting a specific external rule.
- **Governance** = the whole internal system that helps you meet rules consistently.
- **Data lineage** = knowing where data came from and how it changed.
- **Audit trail** = a record proving what happened and when.
- **PII** = data that can identify a specific person.
- **Adversarial input** = an input deliberately crafted to fool a model.

5 Domain 5 Exam Watch-Outs

1. AWS Artifact (download AWS's reports) vs. AWS Audit Manager (build your own evidence) - easy to swap, frequently tested.
2. AWS CloudTrail (who did what) vs. Amazon CloudWatch (is it healthy) - different questions entirely.
3. Amazon Macie (data at rest) vs. Bedrock Guardrails PII masking (live data in motion).
4. Data drift (input changed) vs. model drift (output quality declined) - related, not identical.
5. AWS Control Tower, AWS Organizations, and AWS WAF are explicitly **out of scope** for this exam - if they appear as an answer choice, they are very likely a distractor.

"If the Question Says..." Exam Clue Pairs

If the question says...	Think...
"...never cross the public internet..."	AWS PrivateLink
"...who invoked this model and when..."	AWS CloudTrail
"...download AWS's compliance report..."	AWS Artifact
"...continuously prove our own compliance..."	AWS Audit Manager
"...sensitive data hiding in our S3 data lake..."	Amazon Macie
"...redact PII from a live chatbot response..."	Bedrock Guardrails
"...accuracy quietly dropped over months..."	SageMaker Model Monitor (drift)
"...input designed to bypass instructions..."	Prompt injection
"...no hardcoded credentials for a SageMaker job..."	IAM execution role
"...keep training jobs from reaching the internet..."	SageMaker network isolation

PART 9: DOMAIN 5 SUMMARY AND REVIEW PLAN

5 Key Domain 5 Takeaways

1. **The Shared Responsibility Model is the backbone of this entire domain.** Nearly every Domain 5 scenario can be partially answered by first asking: “Is this AWS’s job, or the customer’s job?”
2. **Generative AI introduces genuinely new security risks** - prompt injection, model inversion, adversarial inputs - that did not exist in traditional application security, and AWS-native defenses like Bedrock Guardrails exist specifically to address them.
3. **Compliance and governance are related but distinct.** Compliance is meeting a specific external requirement; governance is the broader internal system of policy, process, and oversight that helps an organization consistently meet those requirements.
4. **Several AWS service pairs are commonly confused** on this exam: Artifact vs. Audit Manager, CloudTrail vs. CloudWatch, and Macie vs. Bedrock Guardrails PII masking. Mastering the distinction in each pair resolves a large share of Domain 5 exam questions.
5. **Monitoring AI systems doesn’t stop at deployment.** Data drift and model drift are ongoing realities of production AI, and tools like SageMaker Model Monitor exist because “it worked when we launched it” is not the same as “it still works today.”

Remediation Plan for Scores Below 60%

If your Domain 5 practice question results are below 60%, follow this targeted remediation path before moving on:

1. **Re-read Part 3A (Shared Responsibility) and Part 3F (Monitoring/Logging) first.** These two sub-sections resolve the highest concentration of commonly missed questions.
2. **Re-take only the questions you missed**, and for each one, identify whether you missed it due to (a) not knowing the AWS service, (b) confusing two similar services, or (c) misreading the scenario. This diagnosis changes what you study next.
3. **Rebuild the comparison tables from memory** (Part 5) without looking - especially Table 3 (CloudTrail/CloudWatch/Model Monitor) and Table 4 (Macie vs. Guardrails PII masking).
4. **Drill the flashcards in Part 7**, focusing first on the Comparison Cards (26-30), since confused service pairs are the most common source of lost points in this domain.
5. **Re-attempt all 25 practice questions after a 24-hour gap**, not immediately - spaced repetition produces better retention than immediate re-testing.

3-Day Domain 5 Review Schedule

Day 1 (60-75 minutes): - Read Parts 1-3 in full (introduction, task statements, deep dive). - Build your own one-sentence summary of each AWS service mentioned in Part 3, without looking at the text.

Day 2 (60-90 minutes): - Review Part 4 (Key Terms) and Part 5 (Comparison Tables) - self-quiz by covering the right-hand columns and trying to recall them. - Complete Part 7 flashcards (all 30), focusing extra time on Scenario and Comparison cards.

Day 3 (60-90 minutes): - Take all 25 practice questions from Part 6 under light time pressure (aim for under 30 minutes total). - Review every missed question’s rationale carefully. - Finish with the Part 8 cheat sheet as a final rapid-fire self-test.

Security Layer by Layer: A Domain 5 Summary

Think of AI security and governance as a series of concentric layers, each protecting what's inside it:

1. **Data Security (innermost layer):** Encryption at rest and in transit, KMS key management, data masking - protecting the raw data itself.
2. **Access Security:** IAM roles, policies, and the principle of least privilege - controlling who and what can reach the data and the AI services.
3. **Network Security:** VPCs, VPC endpoints, and AWS PrivateLink - controlling how traffic moves and ensuring sensitive paths stay private.
4. **Monitoring and Audit:** CloudTrail, CloudWatch, SageMaker Model Monitor, and Bedrock logging - watching what is happening, both operationally and for accountability.
5. **Governance (outermost layer):** Policies, review cadences, model registries, model cards, and compliance frameworks - the organizational structure that ties every inner layer together and ensures it is maintained consistently over time, not just configured once and forgotten.

A well-designed AI system on AWS has all five layers working together. Weakness in any single layer - say, perfect encryption but no governance process to ensure it stays correctly configured - leaves the whole system exposed. This layered way of thinking is the best mental model to carry into both the exam and real-world AI security conversations.

End of Domain 5 Study Module - Task 6 of 15 Document version: 1.0 / Based on AIF-C01 Exam Guide Version 1.1 (April 30, 2026) Domain 5 Study Module complete.